

CSRF

SSRF

CSRF & SSRF

: REDHAT

목차

Table of Contents

CSRF

CSRF란?
XSS와 차이점
CSRF 방어법

SSRF

SSRF의 개념
SSRF 방어법

코드설명

CSRF
SSRF

문제풀이

dvwa
ccrf / ssrf

마무리

CSRF

CSRF (Cross Side Request Forgery)

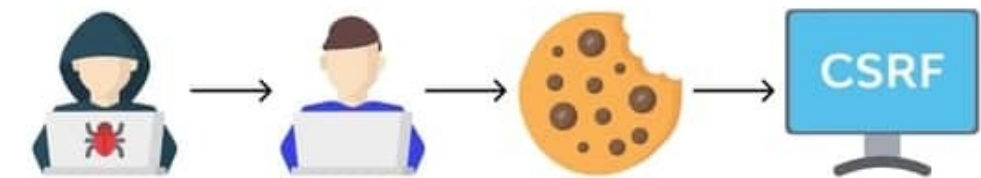
사이트 간 요청 위조 공격

사용자 권한을 이용해 사고를 치는 공격이라고 보면된다.

이미 로그인된 사용자의 권한을 이용하여 서버에 수상한 명령을 내리는 것.

=> 사용자 권한을 이용해 사용자가 의도하지 않은 요청을 보낸다.

CSRF - Cross site request forgery
attack



XSS vs CSRF

XSS

- 웹 사이트에 악성코드를 직접 주입한다.
- 공격자가 웹 사이트를 직접적으로 대놓고 공격
- 스크립트, 다른유저, 서버도 공격 가능

공격흐름

- 공격자가 스크립트를 입력필드에 입력
- 서버가 이를 필터링하지 않고 반영
- 피해자가 페이지에 접속
- 피해자의 브라우저에서 공격코드가 실행됨
- 쿠키탈취, 돔 조작, 관리자 권한 탈취

CSRF

- 정보를 훔치는 것이 공격 목표 X
- 사용자 세션을 이용해 거짓명령을 내리는 것
- 사용자 권한을 악용하여 의도치 않은 요청을 보냄

공격흐름

- 피해자가 사이트에 로그인 (사용자 세션 유지)
- 공격자가 악성링크 / 악성 페이지 제공
- 피해자가 해당 링크 클릭
- 브라우저가 자동으로 요청을 전송함
- 서버는 이를 정상 요청이라 생각하고 처리함

CSRF 방어

CSRF 방어법

- CSRF 토큰 사용
- Samesite 쿠키 사용
- Referer 체크
- 네트워크 분리 (웹서버 와 API등의 서버)

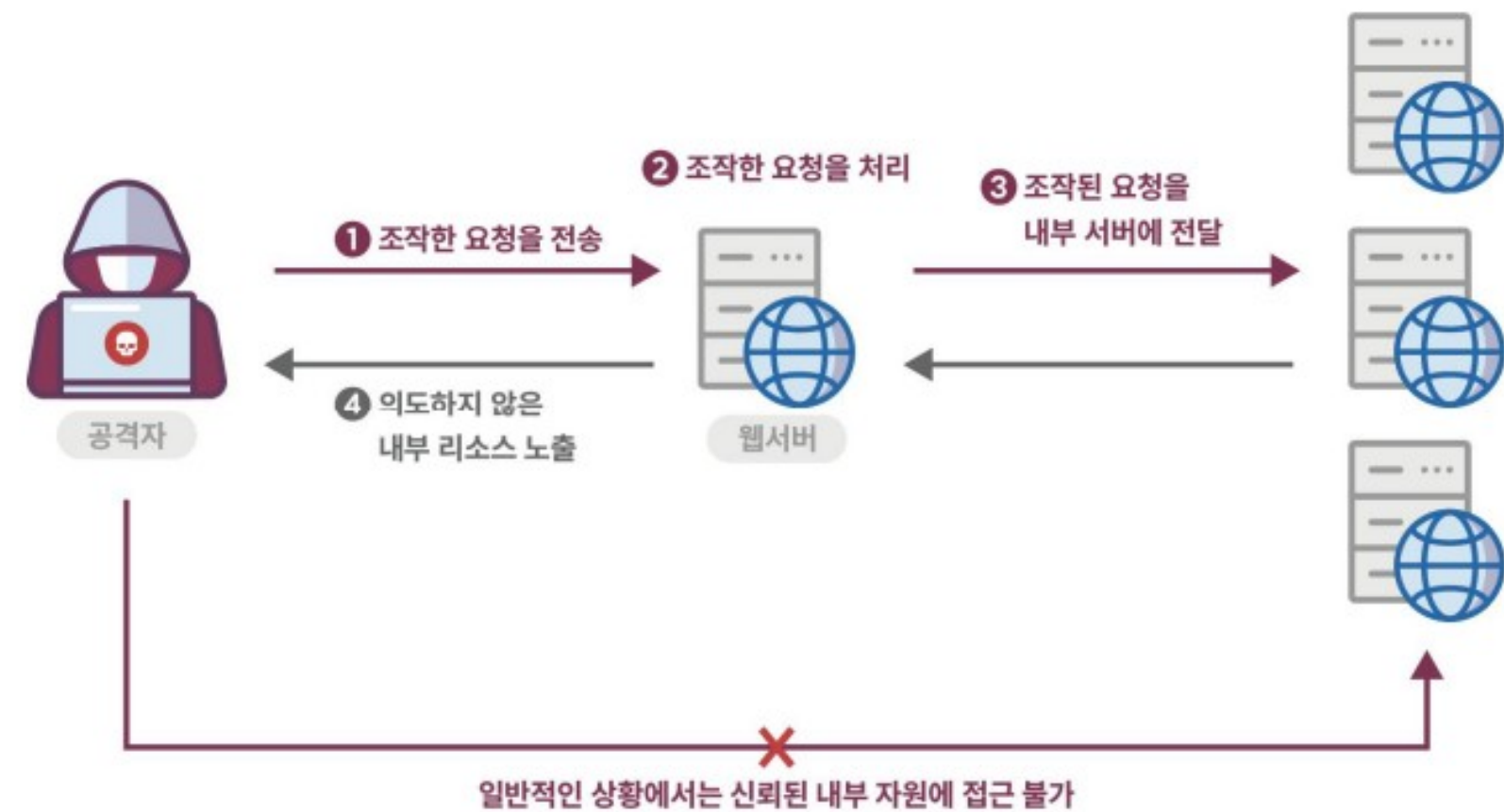
CSRF 방어법

- SOP (Same-Origin Policy) : 동일 출처 정책
- CORS (Cross-Origin Resource Sharing)

SSRF

SSRF (Server Side Request Forgery)

- 공격자가 서버를 프록시로 삼아서 서버가 접근할 수 있는 자원이나 외부 시스템에 강제로 요청을 보내게 하는 공격
- 보통 웹 서버는 방화벽 내부에 위치하여 내부 데이터베이스, 백엔드 API 등에 접근할 수 있는 권한을 가진다.
- 공격자는 이점을 노려, 웹서버를 배달원 느낌으로 쓰는 공격이다.



SSRF 방어법

SSRF 방어법

- URL 스키마 방식을 https만 허용하여 내부파일에 접근하게 만들고 그외는 차단한다.
- 내부서버를 네트워크 상에서 분리를 한다.
- SSRF 공격 탐지가 가능한 snort룰을 설한다.
- 아래 사진은 이글루코퍼레이션의 SSRF(CVE-2019-9621) 스노트 탐지 룰이다.

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"IGRSS.1.02898  
WebApp, Zimbra SSRF, CVE-2019-9621, Attempted Administrator Privilege Gain";  
flow:to_server,established; content:"/service/proxy/?target"; nocase; http_uri;  
content":7071/service/admin/soap/AuthRequest"; distance:0; nocase; http_uri;  
content":7071"; http_header; sid:102898;)
```

코드 설명

dvwa - CSRF

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

Test Credentials

New password:

Confirm new password:

Change

Note: Browsers are starting to default to setting the [SameSite cookie](#) flag to Lax, and in doing so are killing off some types of CSRF attacks. When they have completed their mission, this lab will not work as originally expected.

?password_new=1111&password_conf=1111&Change=Change#

```
if( isset( $_GET[ 'Change' ] ) ) {  
    // Get input  
    $pass_new = $_GET[ 'password_new' ];  
    $pass_conf = $_GET[ 'password_conf' ];  
  
    // Do the passwords match?  
    if( $pass_new == $pass_conf ) {  
        // They do!  
        $pass_new = ((isset($GLOBALS["__mysqli_ston"])) && is  
[MySQLConverterToo] Fix the mysql_escape_string() call! This  
        $pass_new = md5( $pass_new );  
  
        // Update the database  
        $current_user = dvwaCurrentUser();  
        $insert = "UPDATE `users` SET password = '$pass_new'  
        $result = mysqli_query($GLOBALS["__mysqli_ston"], $
```

Webgoat - csrf(3)

CSRF 기본 연습

로그인 상태에서 외부 소스를 통해 아래 양식을 실행하세요. 응답에는 '플래그'(숫자 값)가 포함됩니다.

제출

플래그 확인

이전 페이지에서 획득했어야 할 깃발을 아래에서 확인하세요.

플래그 값 확인:

제출하다



Webgoat - csrf(7)

CSRF 및 콘텐츠 유형

이전 섹션에서 콘텐츠 유형에 의존하는 것이 CSRF 공격에 대한 방어책이 될 수 없다는 것을 살펴보았습니다. 이번 섹션에서는 CSRF 공격에 대한 방어 기능이 없는 API를 대상으로 CSRF 공격을 수행하는 또 다른 방법을 살펴보겠습니다.

이번 과제에서는 다음 JSON 메시지를 당사 엔드포인트로 POST해야 합니다.

```
POST /csrf/feedback/message HTTP/1.1

{
  "name"    : "WebGoat",
  "email"   : "webgoat@webgoat.org",
  "content" : "WebGoat is the best!!"
}
```

더 자세한 정보는 [여기에서](#) 확인할 수 있습니다.

다른 출처(WebWolf를 사용하면 도움이 될 수 있습니다)에서 호출을 해야 하며 WebGoat에 로그인되어 있어야 한다는 점을 기억하세요.

이름

이름을 입력하세요

이메일 주소

 이메일을 입력하세요

주제

하나를 선택하세요: 

메시지

메시지



메시지 보내기

플래그 값 확인: 제출하다

Webgoat - ssrf(3)

← 1 2 3 4 →

서버가 <http://ifconfig.pro> 에서 정보를 가져오도록 요청을 변경하세요.

버튼을 클릭하고 무슨 일이 일어났는지 확인해 보세요.

이것을 시도해 보세요

감사합니다.